

- 1) → A Company hires you to test its network but gives you only a one-line email authorization with no defined scope.

No, I would not exploit the vulnerability because it lies outside the authorized scope of penetration test. Ethical hacking is based on legality, professionalism and respect for the client system. Even if the vulnerability is critical, exploiting it without explicit written permission would violate ethical hacking principles and could expose the tester to legal and contractual consequences.

### Justification using ethical Hacking Principles

- Ethical hacking must always be performed with proper written authorization.
- The email provides only limited permission and does not clearly define systems that may be tested.
- Exploiting an out of scope system may:
  - Damage the client's system
  - cause service disruption
  - violate legal and contractual obligations
  - lead to legal liability for tester.
- The correct action is to
  - stop testing that system
  - Document the discovered vulnerability
  - Inform the client immediately
  - Request written approval before performing any further testing



An ethical hacker follows authorization, legality, confidentiality, integrity and responsibility. Testing beyond the agreed scope is unethical and should never be done without written permission.

## ② SQL injection on production database.

During a penetration test, protecting customer information is the highest priority if the production database contains real customer financial information the penetration tester must ensure that testing does not damage, modify or expose the data.

The SQL injection vulnerability should first be verified using safe and non destructive testing techniques. When real customer financial data is present the priority is to avoid causing harm.

Steps to follow:

1. confirm the SQL injection vulnerability safely.
2. Avoid modifying or deleting any customer data.
3. use read only non destructive payloads whenever possible.
  - a. limit the number of test queries.
5. Record evidence without exposing sensitive information.
6. inform the client immediately after confirming the vulnerability.

Precautions Before the engagement.

- Define a clear scope of testing
- obtain written authorization
- identify production and test environments.



- Confidential  
never
- Create database backups
  - Agree on acceptable testing Methods
  - schedule testing during Maintenance windows.
- 3) Accidental Denial of Service During penetration Test.
- A denial of Services (Dos) attack causing an outage is a serious incident.

How it could have been prevented.

- understand the system before testing
- identify services sensitive to heavy traffic
- Avoid dangerous Dos techniques on production systems.
- Test risky attacks in a staging environment
- follow the agreed rules of engagement
- Co-ordinate testing during Maintenance windows.
- Have emergency contacts available

Responsibility After the incident:

1. stop testing immediately
2. Notify the client without delay
3. Explain the exactly what happened.
4. Assist the client in restoring services
5. Document the incident
6. Recommend measure to prevent similar incidents.

ethical hackers are responsible for minimizing risks, acting honestly reporting incidents immediately and assisting clients during recovery. Professionalism include accepting responsibility and improving future testing Procedures.



- ④ → A client asks you to test their system insists you must inform their IT department waiting to test the team's real world detection capability.

Testing without informing IT department is sometimes performed during red team exercises but it creates significant ethical legal and operational risks.

### Ethical Risks:

- The IT team may mistake the activity for a real cyberattack.
- Security staff could report the tester to law enforcement.
- Employees may panic during the incident.
- Business operations may be interrupted.
- The tester may accidentally damage production systems.

### Practical Risks

- firewalls may automatically block the tester.
- incident response team may isolate important systems.
- Business critical services may become unavailable.
- There may be confusion during emergency response.

### How to structure Engagement

- Obtain written authorization from senior management.
- Prepare a detailed Rules of Engagement document.
- Define testing objectives and scope.
- Specify approved attack techniques.
- Limit testing to approved data and times.
- Conduct a post engagement review.



you asked to perform a Red team exercise versus a vulnerability assessment.

→ Assume a bank wants to evaluate both its cyber security and physical security

→ Although improve security their objectives and Methods are exercises improve security their differences

## Vulnerability Assessment

Objective:

The purpose is to identify analyse and report security

Approach:

- Scan network vulnerabilities
- Review operating system and software
- check security configurations.
- Assess password policies
- Identify missing security patches
- Review firewall configurations
- Prepare a detailed remediation report.

## Ethics

- Non destructive testing
- Minimal impact on Banking operations
- No unnecessary exploitation.
- Protect customer information.
- Follow client authorization.
- Deliverables
  - Vulnerability report
  - Risk ratings



- Recommended fixes
- Security improvement plan.

### Red team Exercise.

Purpose: Simulate real cybercriminal attack

#### Approach:

- Attempt phishing attacks
- Test employee awareness
- Try physical access restricted areas.
- Attempt network compromise
- Test incident detection & responses.

#### Ethics

- strict written authorization
- clearly defined rule of engagement
- safety controls to prevent business disruption.
- Protect customer data
- Immediate reporting of critical findings.